

Threat Modelling Tools

At the start of the lab I successfully downloaded all the threat modelling tools and set them up, while exploring them I noticed that even though they are meant for the same purpose they actually work quite differently, i used OWASP Threat Dragon, Microsoft Threat Modeling Tool and IriusRisk Community Edition.

From my experience, OWASP Threat Dragon feels more like a manual approach. At the start it can be a bit confusing, but once you get used to it, it gives you more control over how build your model, since it is open-source, it is also easy to access and use. One thing I liked about OWASP is the interface, it is quite simple and the drag-and-drop feature makes it easy to create Data Flow Diagrams without too much effort. It also allows exporting work in different formats like JSON or images, which is useful for sharing, which are strong points of the tool, but there are also some weaknesses, it is quite limited in terms of features and mostly focuses on DFDs. Compared to other tools, it doesn't provide very detailed or structured threat analysis, so sometimes you need to do more work manually.

To get more familiar with the tools, I tried to recreate the same "Main Request Data Flow" diagram in all three tools. This helped me understand the differences better.

In OWASP Threat Dragon, it was straightforward and easy to see the whole system clearly.

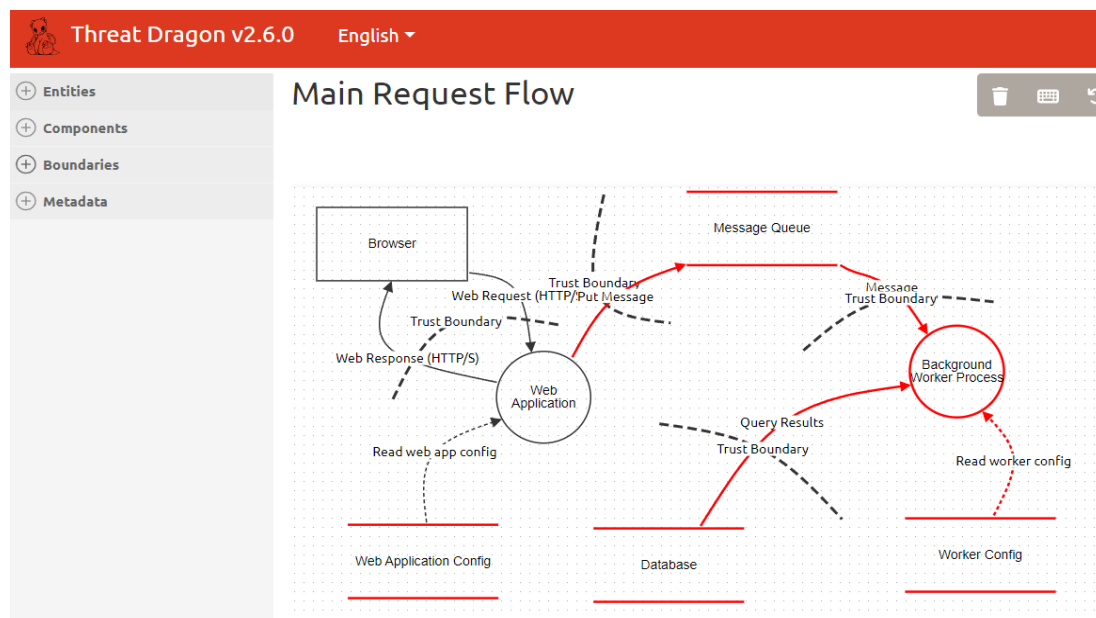


Figure 1. Main Request Data Flow in OWASP Threat Dragon

In the Microsoft Threat Modeling Tool, the process was more structured, and I had to think more about things like trust boundaries and system components. This is one of its main strengths, as it follows a more formal approach and helps identify threats in a more systematic way, it also generates threats automatically, which is very useful.

But MTM tool is less user-friendly and feels more complex, it's not as flexible and takes more time to build the diagram compared to OWASP.

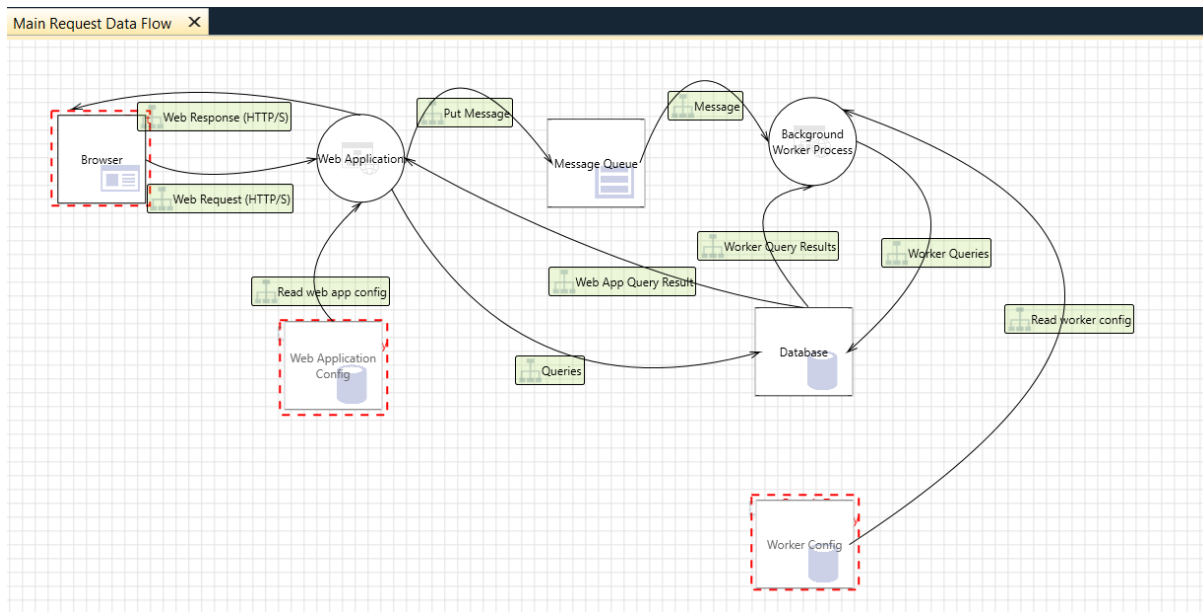


Figure 2. The same data flow in Microsoft Threat Modeling Tool

In IriusRisk, the tool was more guided and automated, which made it easier in some ways, but also less flexible. Comparing both OWASP Threat Dragon and the Microsoft Threat Modeling Tool, I would choose OWASP for simpler tasks, learning or quick modelling as it is easier to use and gives a clear overview of the system. On the other hand, I would choose the Microsoft Threat Modeling Tool for more complex or professional projects where a structured and detailed analysis is required.

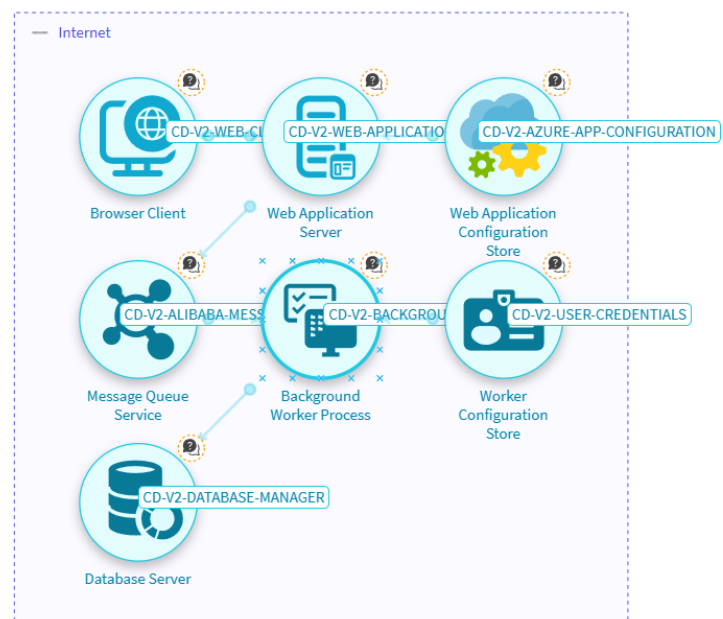


Fig3. Model recreated in IriusRisk Community Edition

Personally, I prefer OWASP Threat Dragon because it is easier to use and gives a clear overall picture. It was quicker for me to build the diagram and understand what is going on. But I can see that in real-world situations MTM might be more useful as it follows a more professional and structured approach.